TECHNICAL DOCUMENTATION / API CONSUMERS

Eligibility API

INTEGRATION & CALLER REFERENCE

MSISDN + National ID pair eligibility lookup

API CONTRACT • SECURITY • RESPONSES • ERROR HANDLING • OPERATIONS

DECISION CONTRACT

Only an HTTP 200 response contains a business decision. Eligibility requires result = OK; result = KO is a rejection. All non-200 responses mean no eligibility decision was made.

DOCUMENT DETAILS

Edition	1.0 · 21 October 2026
Audience	API consumers, integration engineers, and operations teams
Scope	Caller-facing contract documented in the provided source guide
Classification	Internal integration reference

Source: Supplied “Eligibility API — caller guide”. Endpoint behavior reflects that guide, not an independent runtime verification.

EXECUTIVE QUICK REFERENCE

Integration at a glance

The API determines eligibility using an exact **(MSISDN, NID)** pair. A blacklist match for one NID does not apply to the same MSISDN under a different NID.

HTTP base	http://<host>:8080
Eligibility check	POST /api/v1/eligibility/check
Authentication	X-API-Key: <key>
Payload	application/json · msisdn + nid
Request tracing	requestId + X-Request-Id

Decision handling

HTTP 200	**result = OK**	Eligible: caller may proceed with the product.
HTTP 200	**result = KO**	Not eligible: retain the supplied anti-fraud reason.
Any non-200	**No decision**	Do not grant the product; handle the transport/service error.

FAIL CLOSED

A stale or unavailable blacklist, a failed audit pipeline, or a down readiness probe does not produce an eligibility approval.

Contents

01 Base URL
02 Authentication
03 Endpoints
04 Check eligibility
05 Decision scenarios
06 Status codes
07 Examples
08 System status
09 Blacklist file the API loads
10 Message text
11 Caller rules

CALLER CONTRACT AND TECHNICAL DETAILS

This document is for the team that calls the eligibility API. It describes the live contract: endpoints, request and response bodies, status codes, decision scenarios, and how to authenticate.

The lookup key is the pair **MSISDN + national id (NID)**. A number that is blacklisted for one national id is not blacklisted for a different national id.

01 Base URL

The service listens on HTTP port `8080` unless operations changed `server.port`.

```
http://<host>:8080
```

Use the host name operations gives you. Do not call the API from the public internet.

02 Authentication

What is implemented

Every business call requires a shared API key in the header `X-API-Key`.

- The key is compared in constant time.
- A missing or wrong key returns HTTP `401` and is not written to the audit log.
- Do not put the key in the URL, a query string, or a log line.
- The example key used during the first install is a test secret. Production uses a different value stored in `MSISDN_API_KEY`.

Liveness and readiness probes do not require the key:

- `GET /actuator/health/liveness`
- `GET /actuator/health/readiness`

`GET /api/v1/system/status`, `GET /actuator/health`, `GET /actuator/metrics`, and `GET /actuator/prometheus` require the key when `security.protect-actuator` is true, which is the production setting.

Recommended production control

The strongest caller identity for this service is **mutual TLS (mTLS)**: the caller presents a client certificate, and a reverse proxy in front of the API accepts only that certificate. That proves which system is calling without placing a shared secret in every request.

mTLS is the recommended production control. It is **not enabled in this release**. The process speaks HTTP and authenticates with the API key above. Turning on mTLS needs a TLS proxy (or a keystore the service account can read) and a certificate issued to the calling system. Do not assume a call is protected by a client certificate until operations confirms the proxy is in place.

Until that proxy exists, call the API like this:

1. Keep the caller and the API on the internal network. Restrict the source addresses at the firewall to the calling systems.
2. Send `X-API-Key` only in the header, over a private path. Prefer TLS in front of the process as soon as a proxy is available, even before client certificates.
3. Store the key in the caller's secret store. Rotate it by changing `MSISDN_API_KEY` and restarting the API, then updating the caller.
4. Do not log the full request body. Mask MSISDN and NID in caller logs (keep a short prefix and suffix).
5. Treat HTTP `200` with `result KO` as a business rejection, and every other non-200 status as "do not treat the subscriber as eligible."

03 Endpoints

Method	Path	Auth	Purpose
`POST`	`/api/v1/eligibility/check`	API key	Decide one MSISDN + NID pair
`GET`	`/api/v1/system/status`	API key	Operational snapshot for support
`GET`	`/actuator/health/liveness`	none	Process is up
`GET`	`/actuator/health/readiness`	none	Safe to send eligibility traffic

`Content-Type` for the check call must be `application/json`. Unknown JSON properties are rejected.

04 Check eligibility

```
POST /api/v1/eligibility/check
Content-Type: application/json
X-API-Key: <key>
```

```
{
  "msisdn": "201066257228",
  "nid": "29901011234567"
}
```

Field	Required	Rule
`msisdn`	yes	12 digits, pattern `^20[0-9]{10}$`
`nid`	yes	14 digits, pattern `^[0-9]{14}$`

Both values are matched as numbers. A leading zero is not significant. The configured NID pattern is 14 digits and does not allow a leading-zero-only difference to represent a different person.

Eligible — pair absent, or every flag is 0

HTTP `200`

```
{
  "requestId": "req-7c2a0b1e-4f0a-4c1d-9a11-0b5e6d7c8a90",
  "msisdn": "201055555555",
  "nid": "29901011234560",
  "result": "OK",
  "reason": "",
  "blacklistVersion": "20261015"
}
```

`reason` is an empty string on `OK`. `requestId` is also returned in the `X-Request-Id` response header.

Not eligible — one or more flags are 1

HTTP `200`

```
{
  "requestId": "req-001",
  "msisdn": "201066257228",
  "nid": "29901011234567",
  "result": "KO",
  "reason": "Anti-fraud : Anti-Fraud (Vishing), Anti-Fraud (Financial Fraud)",
  "blacklistVersion": "20261015"
}
```

On `KO`, `reason` is one string:

```
Anti-fraud : <display name>, <display name>, ...
```

The names are the display names of every flag that is `1`, in CSV column order, separated by a comma and a space. There is a space before and after the colon. A single flag looks like:

```
Anti-fraud : Anti-Fraud (Suspicious IMEI)
```

Same MSISDN, different NID

The cache key is the pair. This body is `OK` when only `201066257228` + `29901011234567` is blacklisted:

```
{
  "msisdn": "201066257228",
  "nid": "25505051234561"
}
```

05 Decision scenarios

Situation	HTTP	`result`	`reason`
Pair is not in the loaded blacklist	200	`OK`	`""`
Pair is present and every flag is `0`	200	`OK`	`""`
Pair is present and any flag is `1`	200	`KO`	`Anti-fraud : ...` with every active display name
Same MSISDN with a different NID that is not listed	200	`OK`	`""`
Same NID with a different MSISDN that is not listed	200	`OK`	`""`
Blacklist is not loaded, stale, or readiness is down	503	none	Do not treat the caller as eligible
`msisdn` or `nid` missing, blank, wrong type, or failing the pattern	400	none	No eligibility decision
Unknown JSON property, malformed JSON, or non-JSON body that still parses as the wrong shape	400	none	No eligibility decision
`Content-Type` is not JSON	415	none	No eligibility decision
API key missing or wrong	401	none	Not audited
Audit queue cannot accept the event in time, disk is below the floor, or the audit writer is down	503	none	No `OK` is returned

An absent pair is eligible. The API does not return `KO` because the MSISDN alone appears on another row.

06 Status codes

200 OK

The body is an eligibility decision. `result` is `OK` or `KO`. This is the only status that may be treated as a decision.

Fields, when enabled in configuration (all are enabled in production):

Field	Present	Meaning
`requestId`	yes	`req-` plus a UUID
`msisdn`	yes	Echo of the request
`nid`	yes	Echo of the request
`result`	always	`OK` or `KO`
`reason`	yes	Empty string for `OK`. `Anti-fraud : ...` for `KO`
`blacklistVersion`	yes	Version of the file in memory, normally `YYYYMMDD`

400 Bad Request

Validation failed. The decision was not made. Example:

```
{
  "requestId": "req-...",
  "timestamp": "2026-10-15T12:00:00.000Z",
  "status": 400,
  "error": "Bad Request",
  "message": "nid does not match the configured pattern",
  "path": "/api/v1/eligibility/check"
}
```

Typical `message` values:

- `msisdn must not be blank` or `nid must not be blank`
- `nid is required`
- `nid length must be between 14 and 14`
- `nid does not match the configured pattern`
- the same three forms for `msisdn`
- `request body is not valid JSON` (malformed JSON, a wrong JSON type, or an unknown property)

401 Unauthorized

```
{
  "requestId": "req-...",
  "timestamp": "2026-10-15T12:00:00.000Z",
  "status": 401,
  "error": "Unauthorized",
  "message": "A valid API key is required",
  "path": "/api/v1/eligibility/check"
}
```

415 Unsupported Media Type

`Content-Type` was not `application/json`.

```
{
  "requestId": "req-...",
  "timestamp": "2026-10-15T12:00:00.000Z",
  "status": 415,
  "error": "Unsupported Media Type",
  "message": "Content-Type must be application/json",
  "path": "/api/v1/eligibility/check"
}
```

503 Service Unavailable

The API cannot answer safely. **Do not grant the loan.** A missing blacklist is `503`, never `OK`.

```
{
  "requestId": "req-...",
  "timestamp": "2026-10-15T12:00:00.000Z",
  "status": 503,
  "error": "Service Unavailable",
  "message": "Blacklist is not loaded",
  "path": "/api/v1/eligibility/check"
}
```

Other `message` values:

- `Blacklist is not loaded`
- a freshness message when the loaded file is older than the configured maximum age
- `Audit writer is not running`
- `Free disk space is below monitoring.disk-space-threshold-bytes`
- `Audit queue utilization exceeded the readiness threshold`
- `Audit pipeline did not accept the event within 10ms` (the timeout is configured)

Readiness returns HTTP `503` with `"status":"DOWN"` in the same situations. Liveness can still be `200` / `UP`.

500 Internal Server Error

Unexpected failure. The body does not include a stack trace.

```
{
  "requestId": "req-...",
  "timestamp": "2026-10-15T12:00:00.000Z",
  "status": 500,
  "error": "Internal Server Error",
  "message": "An unexpected error occurred",
  "path": "/api/v1/eligibility/check"
}
```

07 Examples

Eligible pair (not in the blacklist):

```
curl -sS -D - http://<host>:8080/api/v1/eligibility/check \
  -H 'Content-Type: application/json' \
  -H "X-API-Key: ${MSISDN_API_KEY}" \
  -d '{"msisdn":"201055555555","nid":"29901011234560"}'
```

Blacklisted pair:

```
curl -sS http://<host>:8080/api/v1/eligibility/check \
  -H 'Content-Type: application/json' \
  -H "X-API-Key: ${MSISDN_API_KEY}" \
  -d '{"msisdn":"201066257228","nid":"29901011234567"}'
```

Expected `KO` body when that pair has Vishing and Financial Fraud set:

```
{
  "requestId": "req-...",
  "msisdn": "201066257228",
  "nid": "29901011234567",
  "result": "KO",
  "reason": "Anti-fraud : Anti-Fraud (Vishing), Anti-Fraud (Financial Fraud)",
  "blacklistVersion": "20261015"
}
```

Missing national id:

```
curl -sS -w '\n%{http_code}\n' http://<host>:8080/api/v1/eligibility/check \
  -H 'Content-Type: application/json' \
  -H "X-API-Key: ${MSISDN_API_KEY}" \
  -d '{"msisdn":"201055555555"}'
```

HTTP `400`.

Wrong key:

```
curl -sS -w '\n%{http_code}\n' http://<host>:8080/api/v1/eligibility/check \
  -H 'Content-Type: application/json' \
  -H 'X-API-Key: wrong-key' \
  -d '{"msisdn":"201055555555","nid":"29901011234560"}'
```

HTTP `401`.

08 System status

```
curl -sS http://<host>:8080/api/v1/system/status \
  -H "X-API-Key: ${MSISDN_API_KEY}"
```

HTTP `200` with the application version, instance id, uptime, readiness, blacklist version and record count, audit queue depth, and Oracle and CSV writer status. The body does not contain the API key, the database password, or the JDBC URL.

Send eligibility traffic only when `ready` is true and `GET /actuator/health/readiness` is HTTP `200`.

09 Blacklist file the API loads

Callers do not upload this file. It is here so the sample rows in this guide can be reproduced.

```
MSISDN,NID,Vishing,Suspicious_IMEI,Financial_Fraud
201066257228,29901011234567,1,0,1
201012345678,28802021234568,0,1,1
201098765432,27703031234569,1,0,0
201055555551,26604041234560,0,0,0
```

Column 1 is the MSISDN. Column 2 is the NID. Every following column is a flag, `0` or `1`. The in-memory cache holds the whole file, keyed by the pair. Bit 0 is the first flag column.

10 Message text

The sentences in this guide are the defaults shipped in `application.yml`. Operations can change every status phrase and every `message` value under `api.error.status-text` and `api.error.messages`, and can change the KO prefix under `api.response.ko-reason-prefix`. Callers should branch on the HTTP status and on `result`. Do not branch on the exact wording of `message` or `reason`.

11 Caller rules

- Send both `msisdn` and `nid` on every check.
- Grant the product only on HTTP `200` and `"result":"OK"`.
- Show or store `reason` when `"result":"KO"`. The string already lists every anti-fraud cause.
- Retry HTTP `503` after readiness is up. Do not retry `400` without changing the body.
- Keep `requestId` from the response or `X-Request-Id` for incident correlation.